FINAL INCIDENT RESPONSE REPORT | Oluwaseun Quadri

Detection and Containment of Web and SSH Brute Force Attacks in a Simulated Enterprise Environment

1.Executive Summary

This project simulated a small-scale enterprise network to demonstrate how organizations build, attack, defend, and monitor their infrastructure.

The environment included:

- A vulnerable web server running **Damn Vulnerable Web Application (DVWA)**
- An SSH honeypot using **Cowrie**
- Centralized logging with **Elastic Stack**
- Active firewall defense using UFW

Two primary attack simulations were conducted:

1. Web brute force attack against DVWA
2. SSH brute force attack against Cowrie

Both were detected, logged, analyzed, and mitigated successfully.

No real production systems were impacted.

2. Enterprise Environment Overview

The simulated enterprise consisted of:

Attacker Machine

- Kali Linux
- Tools:
    - Nmap (Reconnaissance)
    - Metasploit (Exploitation)

Web Server

- Ubuntu Server

- Running Apache
- Hosting DVWA

Honeypot Server

- Running Cowrie SSH Honeypot

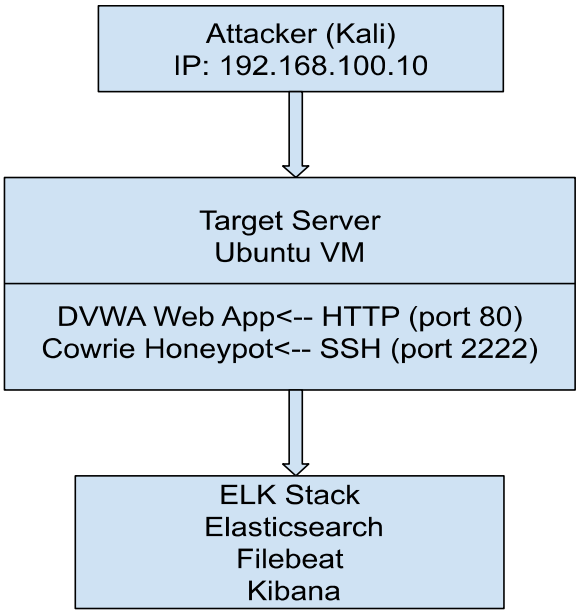
Monitoring Stack

- Elasticsearch (log storage)
- Filebeat (log parsing)
- Kibana (dashboard visualization)

Defense Layer

- UFW Firewall

3. Network Overview



4. Phase 1 – Reconnaissance

Tool used: Nmap

Activities:

- Port scanning
- Service detection

- Identification of open ports (80, 22)

Findings:

- Port 80 open → Web server detected
- Port 22 open → SSH service detected

This information guided targeted brute-force attacks.

5. Phase 2 – Web Application Attack (DVWA)

Target:
DVWA login page

Attack Type:
Brute Force Login Attack

Tool Used:
Metasploit / browser-based brute force simulation

Objective:
Attempt multiple username/password combinations to gain unauthorized access.

Observed Behavior:

- Multiple rapid login attempts
- Repeated failed authentication responses
- High request frequency from single IP

Impact:

If this were a real enterprise:

- Account compromise possible
- Credential stuffing risk
- Unauthorized administrative access

Logs Generated:

- Apache access logs
- Authentication failure logs
- IP address tracking

6. Phase 3 – SSH Honeypot Attack (Cowrie)

Target:
Cowrie SSH Honeypot

Attack Type:
SSH Brute Force

Tool Used:
Metasploit SSH login module

Observed Behavior:

- Multiple username attempts
- Password guessing attempts
- Simulated shell interaction
- Command execution logging

Cowrie captured:

- Source IP address
- Attempted credentials
- Session duration
- Commands executed

This provided valuable attacker behavior intelligence.

7. **Monitoring & Detection (ELK Stack)**

The **Elastic Stack** was configured to ingest logs from:

- Cowrie (JSON logs)
- Web server (Apache logs)

Log Flow:

Cowrie / Apache → Logstash → Elasticsearch → Kibana

Dashboards displayed:

- Top attacking IP
- Login attempts over time
- Failed authentication trends
- SSH session activity
- Web brute force spikes

Security visibility was successfully achieved in near real-time.

8. Containment & Mitigation

After confirming malicious activity:

Firewall rule inserted:

sudo ufw insert 1 deny from 192.168.100.10

Result:

- Attacker IP blocked
- Further connection attempts denied

This demonstrated immediate containment capability.

9. Incident Timeline

Phase	**Activity**
T1	Nmap scan detected open services
T2	Web brute force initiated
T3	SSH brute force initiated
T4	Logs ingested into ELK
T5	Attack patterns visualized
T6	Firewall rule applied
T7	Attack traffic stopped

10. Security Lessons Learned

1. Exposed services are immediately targeted.
2. Brute force attacks are highly automated.
3. Centralized logging is critical for visibility.
4. Honeypots provide valuable threat intelligence.
5. Rapid firewall response reduces risk exposure.

11. Recommendations

- Implement account lockout policy on web applications
- Use ModSecurity WAF for web protection
- Enforce strong password policies
- Use multi-factor authentication (MFA)
- Deploy IDS/IPS for network-level detection

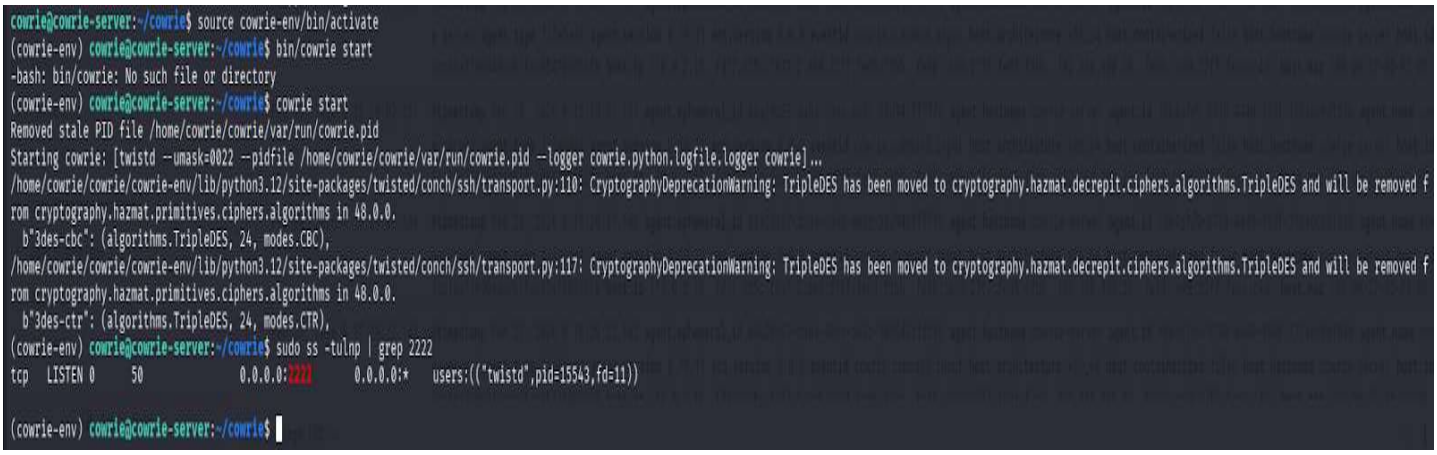


Fig. 1 Image indicating starting of Cowrie Honey-pot and also showing port 2222

Fig. 2 Image indicating using Nmap to scan the open port of 2222

Fig.3 image indicating using ssh to get access to port 222

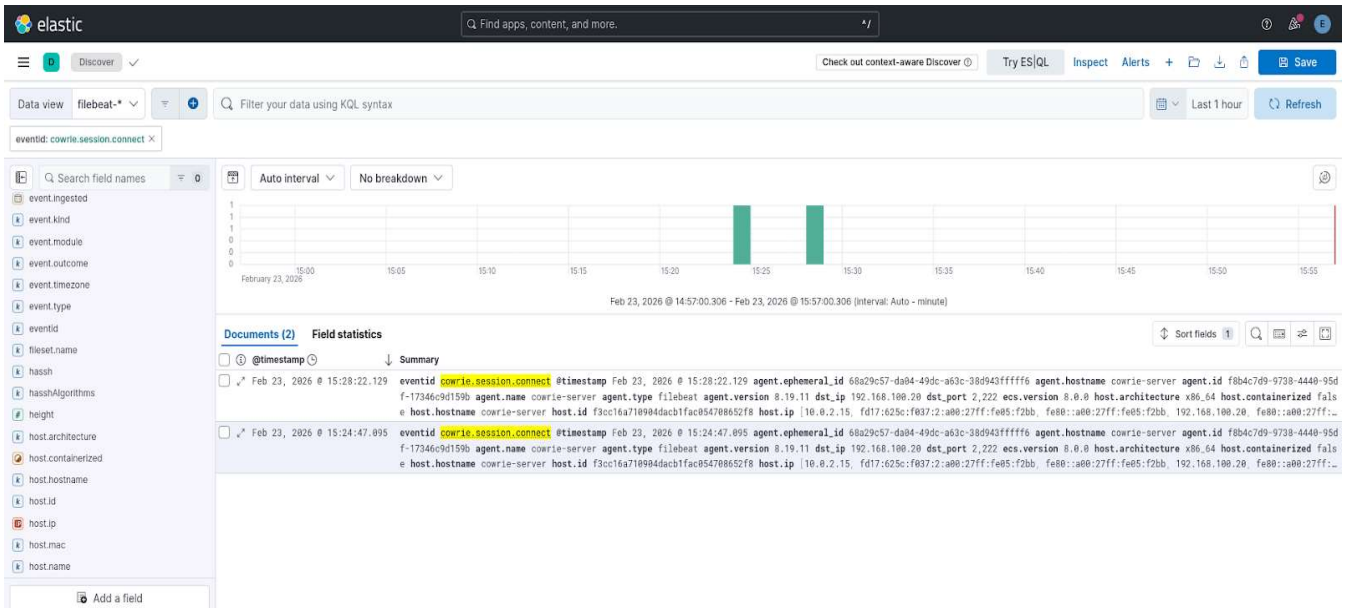


Fig.4 image indicating elk showing logs for cowrie open port

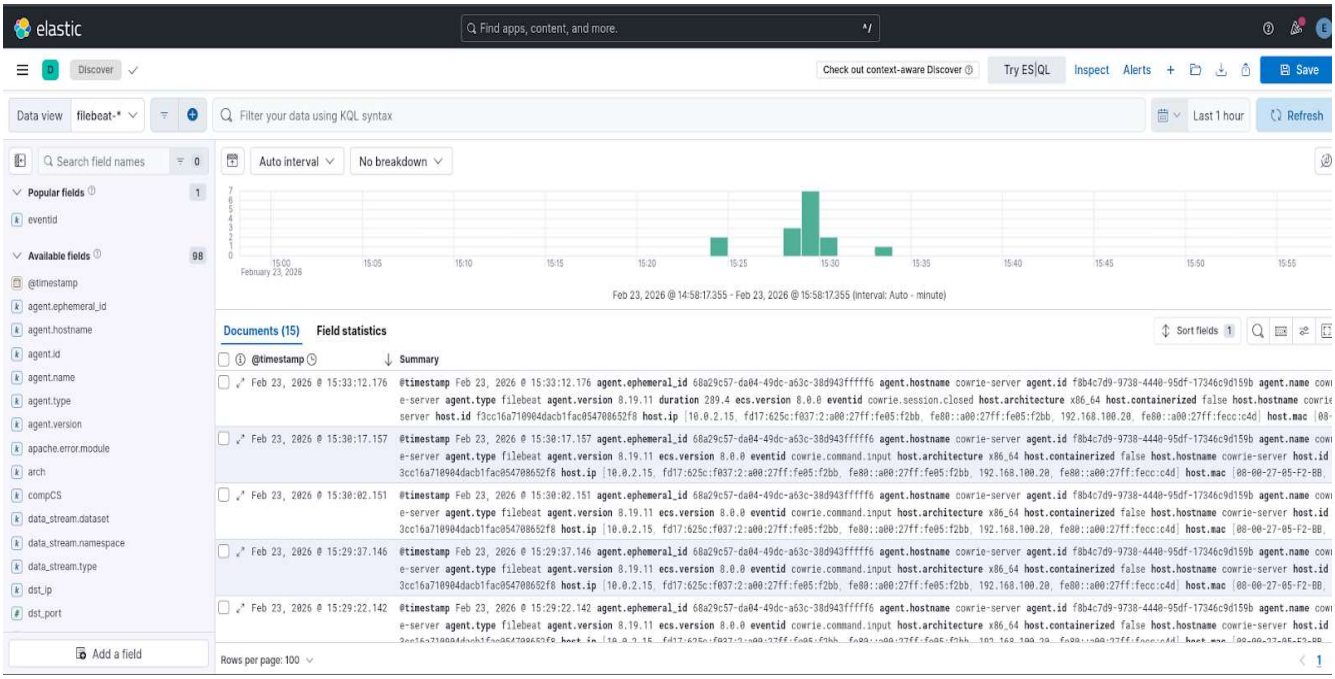


Fig.5 Image indicating the overview of entire logs of both cowrie and DVWA

Fig 6 Image indicating the use of ModSecurity to mitigate attacks

Fig.7 Image indicating the denial of the kali attacker ip

Fig.8 image after enabling the Modsecurity

```
msf > use auxiliary/scanner/http/http_login
msf auxiliary(scanner/http/http_login) > set RHOSTS 192.168.100.20
RHOSTS => 192.168.100.20
msf auxiliary(scanner/http/http_login) > set RPORT 80
RPORT => 80
msf auxiliary(scanner/http/http_login) > set TARGETURI /dvwa/login.php
[!] Unknown datastore option: TARGETURI.
TARGETURI => /dvwa/login.php
msf auxiliary(scanner/http/http_login) > set USERNAME admin
[!] Unknown datastore option: USERNAME. Did you mean HttpUsername?
USERNAME => admin
msf auxiliary(scanner/http/http_login) > set PASS_FILE /usr/share/wordlists/rockyou.txt
PASS_FILE => /usr/share/wordlists/rockyou.txt
msf auxiliary(scanner/http/http_login) > run
[-] http://192.168.100.20:80 No URI found that asks for HTTP authentication
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/http/http_login) >
```

Fig.9 image indicating making use of metasploit to exploit the vulnerabilty

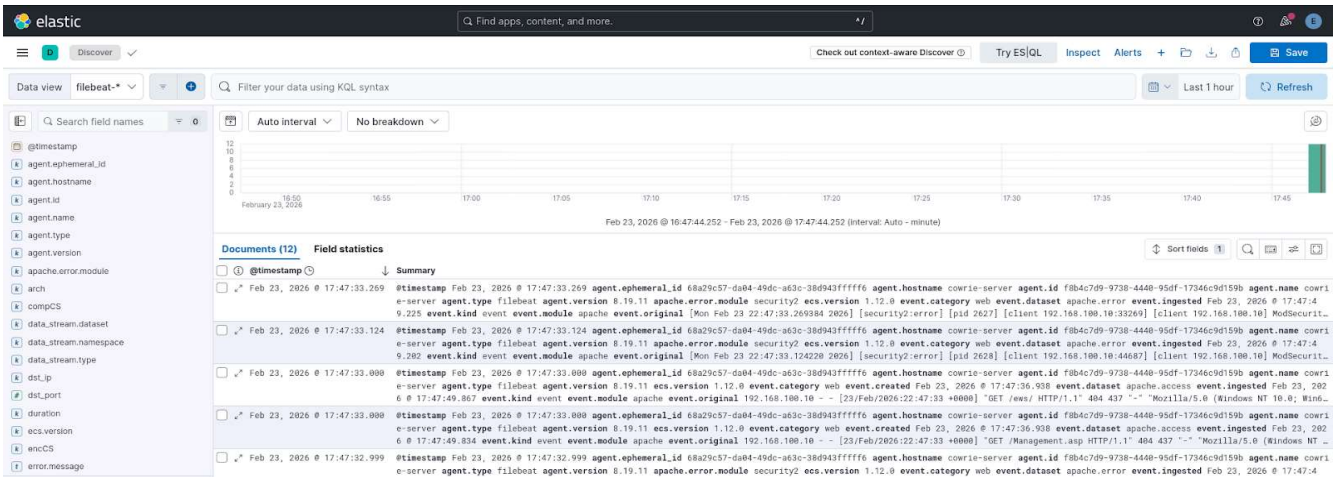


Fig .10 Image indicating the logs from metasploit

```
      =[ metasploit v6.4.111-dev                         ]
+ -- --=[ 2,607 exploits - 1,320 auxiliary - 1,719 payloads    ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use auxiliary/scanner/http/http_login
msf auxiliary(scanner/http/http_login) > set RHOSTS 192.168.100.20
RHOSTS => 192.168.100.20
msf auxiliary(scanner/http/http_login) > set RPORT 80
RPORT => 80
msf auxiliary(scanner/http/http_login) > run
```

Fig 11 image showing denial after enabling ModSecurity

Fig.12 image indicating DVWA running on ubuntu

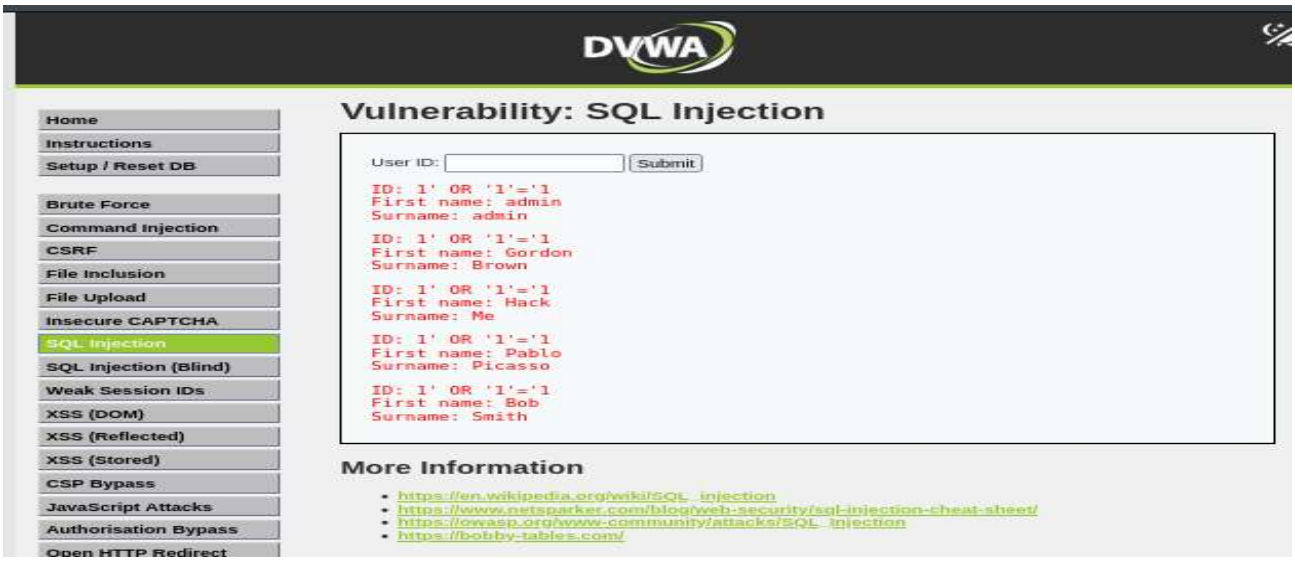
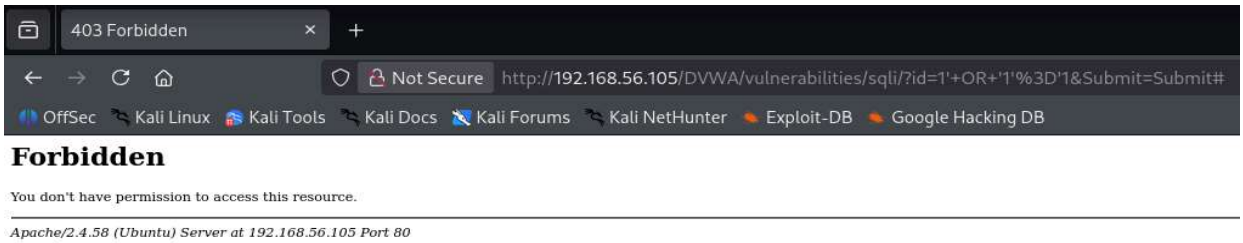


Fig 13. Image indicating Sql injection on DVWA



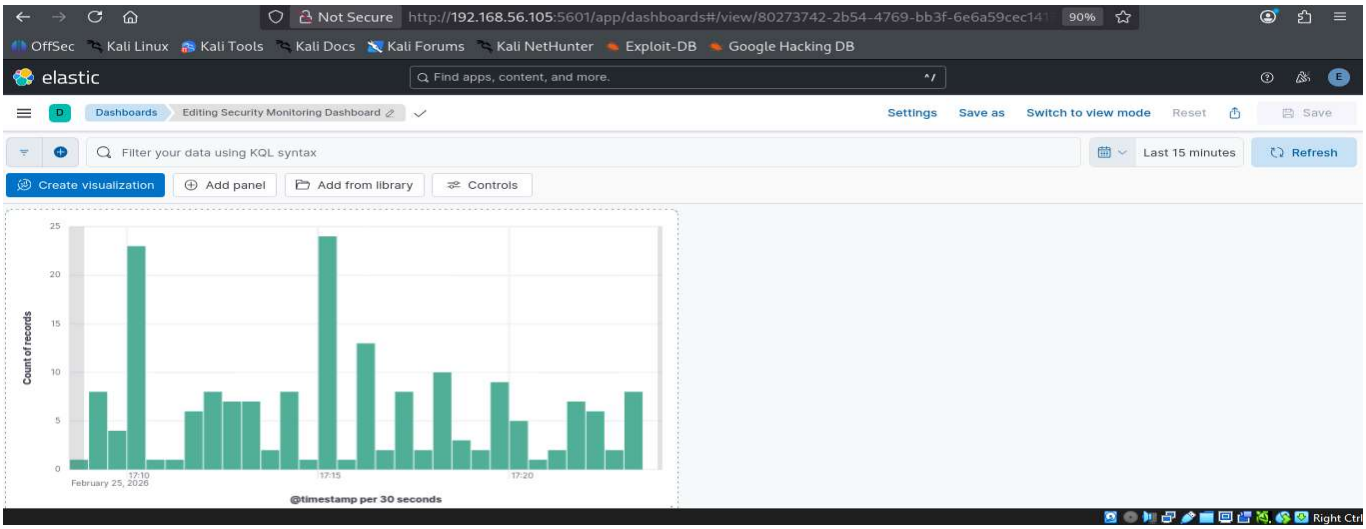


Fig.14 image indicating kibana Dashboard